19 Years of Amazon S3: Why Cloud Data Security is Still Complex to Manage.

Jason Kao, Fog Security

SANS CloudSecNext 2025

About Me

Jason Kao

Founder, Fog Security

Agenda

1. History of S3
2. The Complexity of S3
3. Managing the Complexity of S3 Security
4. Conclusion

The History of S3

19 Years of Amazon S3

2006
Amazon S3 released.

2010
Amazon S3 adds management console functionality.

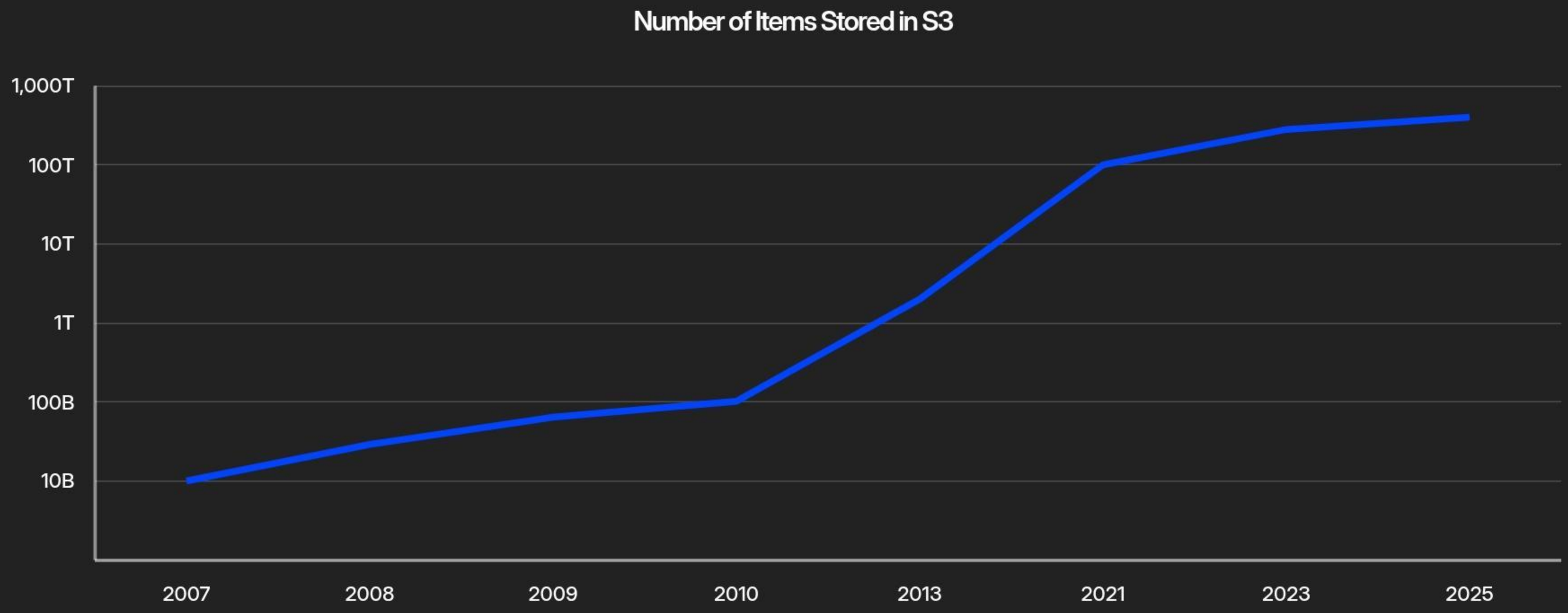
2011
S3 adds support for static web hosting.

2018
AWS adds Block Public Access for S3

2023
S3 encrypts new objects by default

2025
Amazon S3's 19 year anniversary.

S3: The Growth



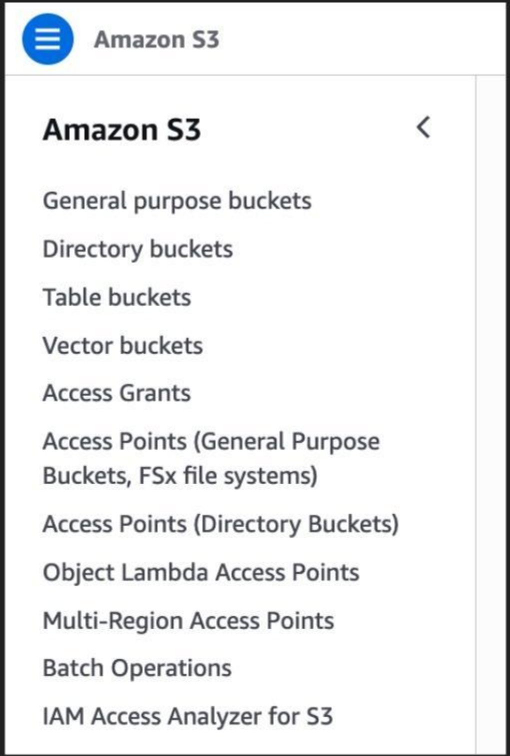
Data from Wikipedia and AWS's News Blogs

The Scale of Amazon S3

- Over 400 Trillion objects
- Exabytes of Data
- 150 million requests per second
- 1000s of AWS customers store over 1 petabyte of data

Amazon S3 Data Sourced from 2025 AWS News Blog

Amazon S3 in 2025



Console Screenshot from AWS, September 2025

S3 in the News

Sensitive Flight Data Exposed

In 2022, an European airline left 6.5 TB worth of EFB data in an unsecured S3 bucket. This included staff data, flight details, and more.

"Codefinger" S3 Ransomware

Originally reported by Halcyon in early 2025. Unique S3 ransomware attacks that leverage SSE-C encryption.

Abandoned S3 Buckets

In 2025, WatchTowr reported 150 abandoned S3 buckets that could be used to attack governments, military networks, Fortune 100s, and more.

The Complexity of S3

Layers of S3 Configuration

Object-Level Configuration

Bucket-Level Configuration

Account-Level Configuration

Organization-Level Configuration

S3 Security and Access Releases

2006
Amazon S3 released

2011
AWS Identity and Access Management goes GA.

2017
AWS introduces Service Control Policies

2018
S3 Block Public Access feature launched

2021
Object Ownership Setting introduced to disable ACLs

2024
AWS introduces Resource Control Policies

Organization Level Controls

- **Service Control Policies**
  A type of organization policy that can be used to to manage permissions in your organization across accounts, OUs, or the organization.

- **Resource Control Policies**
  A type of organization policy that can be used to manage permissions for resources in the organization. These can be applied across accounts, OUs, or the organization.

Account Level Controls

- **Block Public Access**
  A setting that can be used to override public ACLs and public policies, thus blocking public access to S3.

Bucket Level Controls

- **Block Public Access**
  Introduced to prevent accidental public exposure of S3 buckets and objects.

- **Server-Side Encryption**
  Offers default server-side encryption options, including AWS-managed keys and customer-managed keys.

- **Bucket Policies**
  Provides granular access controls at the bucket level to manage public access and permissions.

- **Object Ownership Settings**
  Defines if ACLs are enabled or disabled for the S3 Bucket.

- **ACLs**
  Access Control Lists can be set the bucket level to grant access.

Object Level Controls

- **ACLs**
  ACLs can be set at the S3 object level.
- **Server-Side Encryption**
  Encryption can also be set at the S3 object level when writing objects to S3.
- **Object Lock**
  While this requires enablement at the bucket level, object lock can be used to prevent objects from being deleted or overwritten.

Mistrusted Advisor

HELP NET SECURITY

Zeljka Zorz, Editor-in-Chief, Help Net Security
August 21, 2025

Share

AWS Trusted Advisor flaw allowed public S3 buckets to go unflagged

Vulnerability Management, Cloud Security

AWS Trusted Advisor bug preventing misconfigured S3 bucket detection resolved

August 25, 2025

Share

By SC Staff

SECURITYWEEK
CYBERSECURITY NEWS, INSIGHTS & ANALYSIS

AWS Trusted Advisor Tricked Into Showing Unprotected S3 Buckets as Secure

AWS has addressed a vulnerability that could have been leveraged to bypass Trusted Advisor's S3 bucket permissions check.

Mistrusted Advisor: Evading Detection with Public S3 Buckets and Potential Data Exfiltration in AWS

AUGUST 20, 2025

We found security issues with AWS's Trusted Advisor Service that allowed us to create public S3 buckets while evading detection for potential data exfiltration.

Mistrusted Advisor: Security Finding from 2025

We discovered 3 distinct scenarios where Trusted Advisor's alerting could be bypassed and would not alert on Public Buckets. This included the creation of a bucket policy that blocked Trusted Advisor from at least 1 of the following 3 actions:

- s3:GetBucketACL
- s3:GetBucketPolicyStatus
- s3:GetBucketPublicAccessBlock

As of July 2025, this issue has been fully remediated.

Managing the Complexity

Managing the Complexity: A Strategy

Make the right thing easy to do and the exceptions possible to handle.

Managing the Complexity: A Strategy

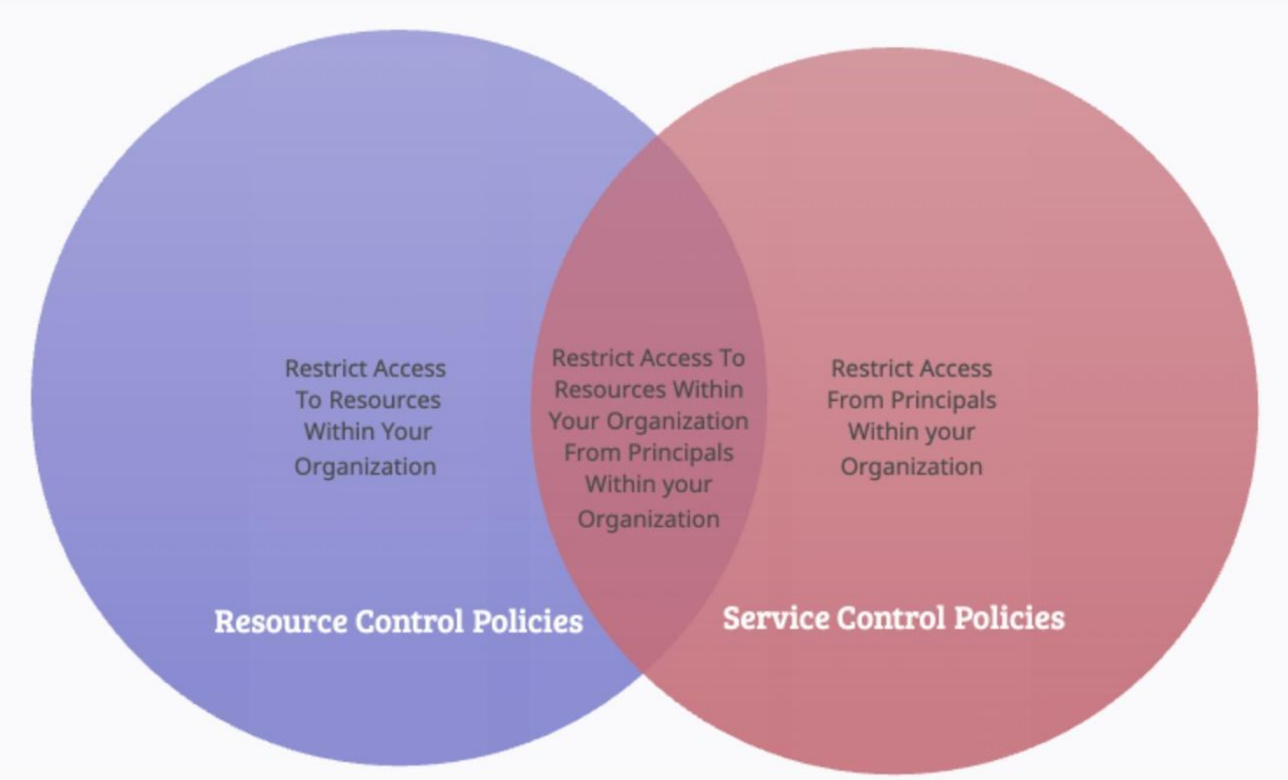
- Create preventative guardrails with data perimeters.
- Streamline access controls in S3 and define patterns.
  For example, retire usage of ACLs.
- Ensure detective controls scan properly for all S3 configuration items.
- Apply controls as appropriate across all 4 levels: Organization, Account, Bucket, and Object.

Preventative Guardrails

- Resource Control Policies
- Service Control Policies
- Account Public Access Block
- Bucket Public Access Block
- Object Ownership Controls (Disabled ACLs)

Organizational Level Controls: SCPs and RCPs

AWS SCP and RCP Usage	Principal within Organization	Principal outside Organization
Resource within Organization	SCPs & RCPs	RCPs
Resource outside Organization	SCPs	NA



Data Perimeter

RCPs: Prevent SSE-C Ransomware

```json
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenySSECEncryption",
      "Effect": "Deny",
      "Principal": "*",
      "Action": [
        "s3:PutObject"
      ],
      "Resource": "*",
      "Condition": {
        "Null": {
          "s3:x-amz-server-side-encryption-customer-algorithm": "false"
        }
      }
    }
  ]
}
```

Data Perimeter

RCPs: Prevent Public S3 Access

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Sid": "BlockPublicAccessToS3",
            "Effect": "Deny",
            "Principal": "*",
            "Action": [
                "s3:*"
            ],
            "Resource": "*",
            "Condition": {
                "StringNotEqualsIfExists": {
                    "aws:PrincipalOrgID": "ORG_ID_HERE"
                },
                "BoolIfExists": {
                    "aws:PrincipalIsAWSService": "false"
                }
            }
        },
        {...}
    ]
}
```

Data Perimeter

Resources

Perimeter	Control Objective	Using	Primary IAM feature
Identity	Only trusted identities can access my resources	RCP	aws:PrincipalOrgID aws:PrincipalOrgPaths aws:PrincipalAccount
	Only trusted identities are allowed from my network	VPC endpoint policy	aws:PrincipalIsAWSService aws:SourceOrgID aws:SourceOrgPaths aws:SourceAccount
Resource	My identities can access only trusted resources	SCP	aws:ResourceOrgID aws:ResourceOrgPaths aws:ResourceAccount
	Only trusted resources can be accessed from my network	VPC endpoint policy	
Network	My identities can access resources only from expected networks	SCP	aws:SourceIp aws:SourceVpc/aws:SourceVpce aws:VpceOrgID aws:VpceOrgPaths aws:VpceAccount
	My resources can only be accessed from expected networks	RCP	aws:ViaAWSService aws:PrincipalIsAWSService

Owned by you

Owned by AWS

GitHub: AWS Samples

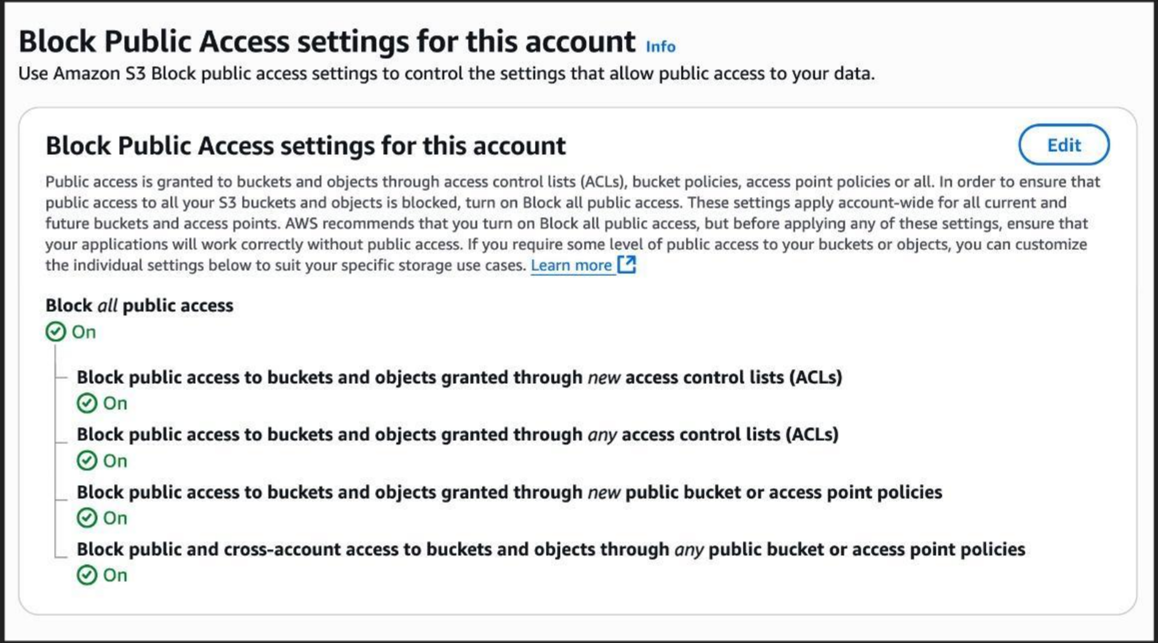
- https://github.com/aws-samples/data-perimeter-policy-examples

GitHub: Fog Security

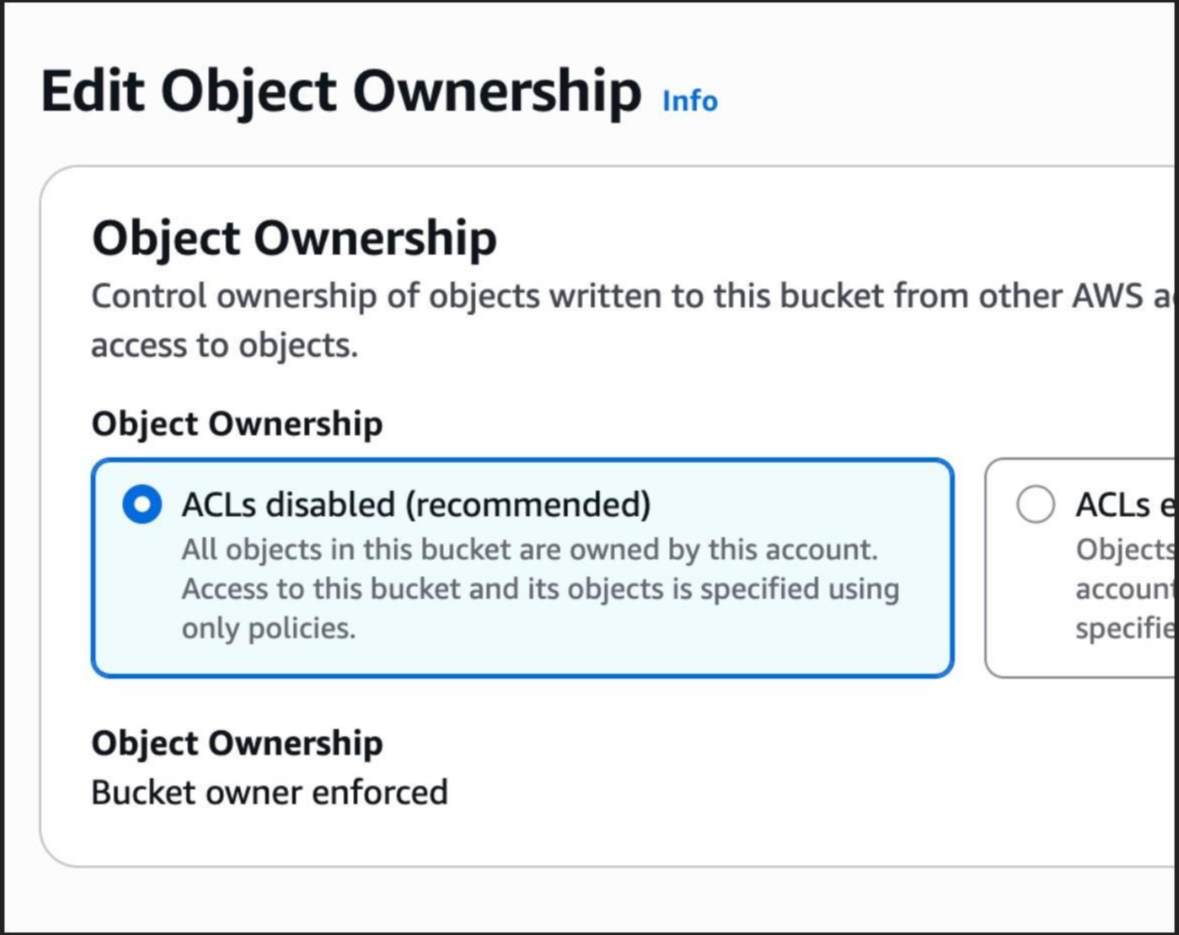
- https://github.com/FogSecurity/aws-data-perimeter-iam

Image from AWS Maturity Model, 2025

Block Public Access: Overriding Public Settings



Retiring ACLs: Object Ownership



S3 Security Settings

Detection and Management

S3 Configuration Items

- Bucket Access Control Lists (ACLs)
- Bucket Policy
- Bucket Website Settings
- Account Public Access Block
- Bucket Public Access Block
- Object Ownership Controls (Disabled ACLs)
- Bucket Encryption Settings
- S3 Server Access Logging
- Object Lock Configuration
- Bucket Versioning Settings
- Bucket Lifecycle Configuration

S3 Access: Evaluation of Public

- **Public via Access Control Lists:**
  - ACLs Enabled for the Bucket
  - Public ACLs
  - Account Block Public Access
  - Bucket Block Public Access
  - Resource Control Policies

- **Public via Bucket Policy:**
  - Public Bucket Policy
  - Account Block Public Access
  - Bucket Block Public Access
  - Resource Control Policies

Conclusion

- With great power comes great responsibility.
- Shift Left: Set guardrails and understand patterns.
- Secure by default settings when applicable.
- Understand S3 security settings and make sure your security tooling understands them too.

Resources

- **Open Source S3 Scanner: YES3 Scanner**
  https://github.com/FogSecurity/yes3-scanner
- **Data Perimeters**
  https://github.com/FogSecurity/aws-data-perimeter-iam
- **Contact Us**
  jason@fogsecurity.io
  https://www.linkedin.com/in/kaojason/